Báo cáo phần việc thành viên

Đơn hàng thanh toán và trả hàng
Đồ án Góc Sách • Nhóm 27

Thông tin	Nội dung
Họ và tên	Lê Trọng Bảo
MSSV	22110106
Đề tài	14 — Website chuỗi cửa hàng sách cũ
Phiên bản	Cập nhật ngày 28/10/2026

Đây là phân công API đã thống nhất ngày 28/10/2026, gồm phần tiếp nhận, kiểm thử và trình bày của thành viên. Tài liệu mô tả phần chức năng có trong source hiện tại, không xác nhận thay lịch sử đóng góp cá nhân. Người đứng tên cần rà soát, chỉnh theo công việc thực tế và tự trình bày được mã nguồn liên quan.

Nhóm việc	Trách nhiệm và nội dung giải thích
Đơn hàng và trả hàng	Phụ trách đơn buyer/seller, chuyển trạng thái, yêu cầu trả, duyệt/từ chối và ghi nhận hoàn tiền bên ngoài. Kiểm tra chủ đơn, quyền shop và thông báo riêng qua WebSocket.
Checkout và payOS	Theo dõi giỏ qua báo giá, fingerprint, khóa bản, idempotency và đơn theo shop. Giải thích tại sao return URL không thể tự đánh dấu PAID, còn webhook phải kiểm tra chữ ký, tiền và mã giao dịch.
Tích hợp và kiểm thử	Chuẩn bị cấu hình mẫu, schema, bộ seed demo; chạy verify và PostgreSQL acceptance. Đối chiếu snapshot số tiền với UI và phân biệt fake gateway với dịch vụ thật.

1 Luồng chức năng và mã nguồn

Khi trình bày, bắt đầu từ thao tác người dùng, theo request đến controller/service, chỉ ra dữ liệu đọc ghi và điều kiện từ chối. Chọn một trường hợp thành công và một trường hợp lỗi có ý nghĩa, tránh chỉ bấm qua màn hình.

Bước	Hoạt động và nhánh xử lý
1	Đăng nhập bằng vai trò phù hợp trong bộ demo; xác định đúng tài khoản/shop/đơn được phép thao tác.
2	Mở chức năng thuộc phạm vi phụ trách, nhập dữ liệu hợp lệ và quan sát kết quả.
3	Đối chiếu với phương thức bên dưới; chỉ ra điều kiện quyền, dữ liệu và trạng thái.
4	Thử dữ liệu sai hoặc quyền không phù hợp; xác nhận server từ chối và dữ liệu quan trọng không bị đổi.

src/main/java/vn/edu/utex/bookstore/payment/PaymentService.java • dòng 141

```
141  public void webhook(String rawJson) {
142  requireEnabled();
143  PaymentGateway.Receipt receipt = gateway.verify(rawJson);
144  if (!receipt.success()) return;
145  if (receipt.orderCode() <= 0 || receipt.amount() <= 0 || !"VND".equals(receipt.currency())
146  || receipt.reference() == null || receipt.reference().isBlank() || receipt.reference().length() > 200
147  || receipt.paymentLinkId() == null || receipt.paymentLinkId().isBlank())
148  throw Problem.invalid("Thông tin thanh toán không hợp lệ.");
149  var payment = store.tx(data -> data.paymentByCode(receipt.orderCode()));
150  // payOS confirms a new webhook using a signed sample which is not a local order.
```

Đoạn code là minh họa từ source bàn giao. Khi bảo vệ cần mở cả phương thức và lớp gọi để giải thích đầy đủ; không coi mười dòng trích là toàn bộ chức năng.

2 Sử dụng AI và tự kiểm chứng

AI giúp liệt kê nhánh lỗi và phác thảo test. Phần quyết định vẫn là ranh giới transaction và trạng thái được phép đổi. Một ví dụ thực tế trong đợt rà soát là báo giá bị khác fingerprint do scale BigDecimal; cách sửa phải được kiểm tra lại trên PostgreSQL chứ không chỉ test bộ nhớ.

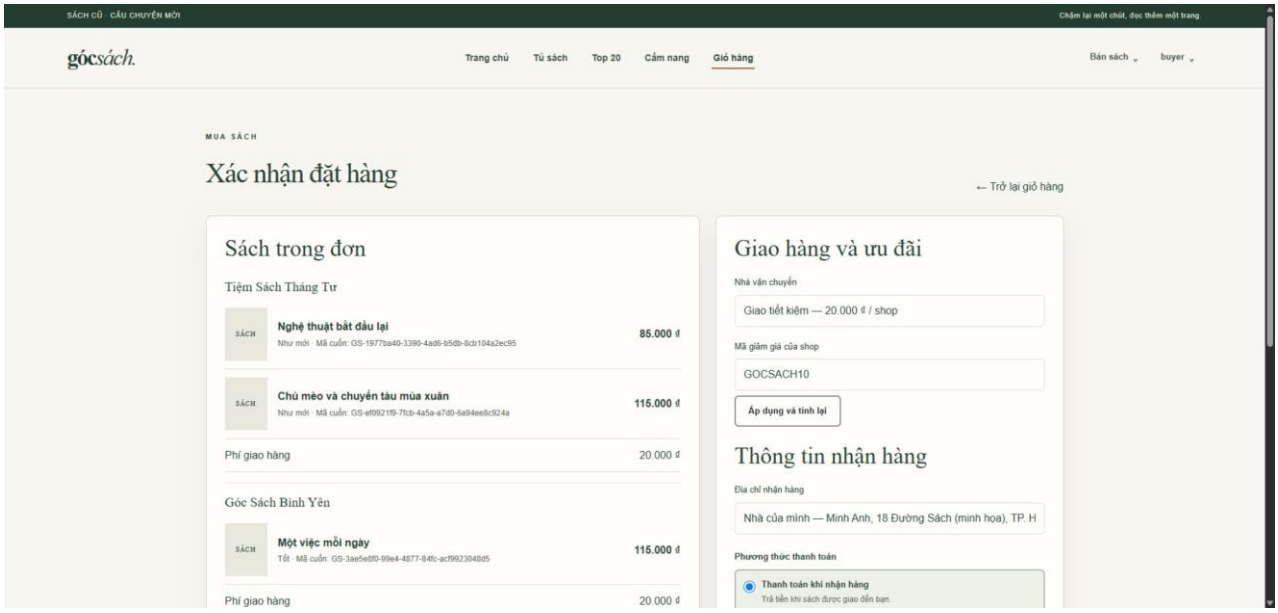
Ví dụ yêu cầu gửi cho AI đã biên soạn lại

Hãy thiết kế bộ ca kiểm thử checkout cho từng bản sách có tồn bằng một, gồm gửi lặp, hai người đặt cùng lúc và giá đổi sau báo giá. Nêu điều kiện transaction cần giữ.

Prompt ở đây diễn đạt lại mục tiêu kỹ thuật để người đọc hiểu cách sử dụng công cụ; không phải bản sao hội thoại hoặc bằng chứng thời điểm một thành viên đã thực hiện. Không ghi nhận kết quả kiểm thử khi chưa chạy và không dùng AI để dựng lịch sử đóng góp.

Cách tiếp nhận kết quả

Bước	Hoạt động và nhánh xử lý
1	Đưa bối cảnh và ràng buộc cụ thể, tránh yêu cầu tạo toàn bộ chức năng mà không có quy tắc.
2	Đọc phương án, đối chiếu với entity, service và quyền hiện có; bỏ gợi ý trái nghiệp vụ.
3	Tích hợp phần nhỏ, chạy test liên quan rồi chạy verify trước khi bàn giao.
4	Mở giao diện, đối chiếu dữ liệu và ghi rõ giới hạn chưa được kiểm tra với dịch vụ thật.



Giao diện minh họa từ ứng dụng local dùng dữ liệu giả.

3 Kiểm thử và kịch bản video

Bộ test chung tại mốc bàn giao đạt 230 test. Thành viên không cần đọc tất cả log trong video, nhưng phải chỉ ra một test sát chức năng mình trình bày, nêu dữ liệu đầu vào, điều kiện mong đợi và kết quả. Fake payment không phải thanh toán ngân hàng thật.

Thời lượng gợi ý	Nội dung
0:00–0:30	Xuất hiện trước camera, giới thiệu họ tên, MSSV và phạm vi đã xác nhận. Hai trường còn trống phải điền trước khi quay.
0:30–1:40	Demo một luồng chính bằng tài khoản đúng vai trò; giải thích dữ liệu trước và sau.
1:40–2:40	Mở controller/service liên quan, giải thích điều kiện quyền và quy tắc dữ liệu.
2:40–3:30	Demo một nhánh lỗi, chạy hoặc mở test có kết quả mới; nói rõ cách xử lý.
3:30–4:00	Nêu cách AI đã hỗ trợ thực tế, phần tự kiểm tra và giới hạn còn lại.

Câu hỏi tự luyện trước khi báo cáo

Dữ liệu này thuộc người dùng hoặc shop nào và server kiểm tra ở đâu?

Nếu request gửi lại hoặc hai người cùng sửa thì điều gì ngăn dữ liệu sai?

Dữ liệu nào được chốt trong đơn và vì sao không đọc giá hiện tại?

Phần nào đang dùng dịch vụ thật, phần nào giả lập; có thể chứng minh bằng test nào?

Bổ sung commit hoặc review thật tương ứng với phần việc đã thực hiện. Không chia tác giả giả hoặc tạo commit rỗng chỉ để làm bằng chứng. Video và phần tự chấm rubric là việc từng thành viên cần tự hoàn tất.

4 URL API thuộc phần phụ trách

Base mặc định http://localhost:8080; demo dùng http://127.0.0.1:18082. Thay port theo máy chạy. Các URL có tham số trong dấu ngoặc nhọn phải thay bằng ID hoặc slug thực tế. API riêng dùng Authorization: Bearer <token>.

Cách lấy token: GET /auth/login để lấy CSRF, POST form đăng nhập cùng cookie; GET lại CSRF rồi POST /auth/api-token. Chi tiết body, query, mã phản hồi và ví dụ có trong API/API_REFERENCE.md kèm hồ sơ. Không tự đưa userId vào body để chọn người dùng khác.

HTTP và URL đầy đủ	Quyền truy cập
POST http://localhost:8080/api/checkout	Bearer, dữ liệu của mình
GET http://localhost:8080/api/checkout/quote	Bearer, dữ liệu của mình
GET http://localhost:8080/api/orders	Bearer, dữ liệu của mình
GET http://localhost:8080/api/orders/{id}	Bearer, dữ liệu của mình
POST http://localhost:8080/api/orders/{id}/cancel	Bearer, dữ liệu của mình
GET http://localhost:8080/api/orders/{id}/payment	Bearer, dữ liệu của mình
POST http://localhost:8080/api/orders/{id}/payment/cancel	Bearer, dữ liệu của mình
POST http://localhost:8080/api/orders/{id}/payment/refresh	Bearer, dữ liệu của mình
POST http://localhost:8080/api/orders/{id}/payment/start	Bearer, dữ liệu của mình
GET http://localhost:8080/api/orders/{id}/return	Bearer, dữ liệu của mình
POST http://localhost:8080/api/orders/{id}/return	Bearer, dữ liệu của mình
GET http://localhost:8080/api/seller/orders	Quyền theo shop
GET http://localhost:8080/api/seller/orders/{id}	Quyền theo shop
POST http://localhost:8080/api/seller/orders/{id}/cancel	Quyền theo shop
POST http://localhost:8080/api/seller/orders/{id}/return/resolve	Quyền theo shop
POST http://localhost:8080/api/seller/orders/{id}/status	Quyền theo shop
GET http://localhost:8080/api/seller/shops/{id}/returns	Quyền theo shop
POST http://localhost:8080/payments/payos/webhook	Chữ ký payOS

Thông báo: ws://localhost:8080/ws, dùng phiên web. Hoàn tiền là ghi nhận bên ngoài, không chuyển tiền tự động. Không coi return URL là bằng chứng đã thanh toán.